

Varakumar G

varakumar7000@gmail.com | +916309856263 | linkedin.com/in/varakumar01
GitHub | GitLab | Portfolio | Letter of Recommendation

PROFESSIONAL SUMMARY

Security Engineer with a strong interest in how technology architecture actually works. Over 2 years managing **Vulnerability Management** across **cloud environments** end-to-end, including fixing **2,800+ CVEs** in OT Security within a year, working solo across a large attack surface. I work with protocols like IPsec, Kerberos, LDAP, Modbus, BACnet, EtherNet/IP, DNP3, PROFINET, and SNMP.

To keep pace with the volume, I automated plugin development for OT security, cutting down manual repetitive work. I also contribute to **open-source** security testing and development projects, mostly because I want the tools I use to stay secure, and that naturally leads me to contribute back.

TECHNICAL SKILLS

Vulnerability Scanning & Management: Nessus, OpenVAS, Qualys, CloudSploit, NVD, Custom Scripts

Exploitation & Network Attack Tools: Metasploit, Burp Suite, Nmap, Wireshark, crAPI, VAmPI, Hashcat

Cloud Security: AWS, Microsoft Azure, Google Cloud Platform (GCP)

Network & Security Protocols: IPsec, Kerberos, LDAP, TLS/SSL, DNS, DHCP, SNMP, SMB, RDP, SSH, HTTP/HTTPS

OT/ICS & Industrial Protocols: Modbus, BACnet, EtherNet/IP, DNP3, PROFINET

Programming & Databases: C, Python, Node.js, Bash, MongoDB, MySQL

Security Frameworks & Standards: MITRE ATT&CK, OWASP Top 10, NIST, CIS Benchmarks

Operating Systems & Platforms: Kali Linux, Arch Linux, NetHunter, WireGuard

PROFESSIONAL EXPERIENCE

Holm Security AB | Security Engineer

Randstad.in

- Maintained security support for OT Security, growing **CVE coverage from 400 to 3,200+** within a year - a **700% increase** in the company's SCADA/OT security coverage for clients.
- Worked across OT security products from **Siemens, Schneider Electric, Rockwell Automation, ABB, Emerson, and Honeywell**.
- Managed the **CloudSploit platform end-to-end** across **AWS, Azure, GCP, and Oracle**, maintaining **CIS benchmark** compliance while maintaining upstream changes for the CloudSploit project.
- Used **Claude AI** to automate security code development for vulnerability management and CloudSploit.
- Worked directly with clients to resolve issues and improve their experience with the company.

Independent Security Assessment

- Bill Manager (Ecommerce/Billing App):**
 - Tested for common web app flaws typical in login-and-role-based systems: **broken access control** between user and admin roles, **insecure direct object reference (IDOR)** on invoices/billing records, **privilege escalation** via role/parameter tampering, **SQL injection** on login and search fields, **stored/reflected XSS**, insecure password reset flow, missing rate limiting on login attempts, and weak **session/JWT** handling.
 - Documented findings and fixes through a **GitHub Security Advisory** on the project repository.
- Web Application Pentesting (PortSwigger Web Security Academy):**
 - Completed hands-on labs across **SQL injection, XSS, CSRF, authentication bypass, access control, SSRF, XXE, insecure deserialization** and **API testing**.
- Active Directory Pentesting:**
 - Practiced core AD attack paths: **Kerberoasting, LLMNR/NBT-NS poisoning, pass-the-hash**, and **privilege escalation** via mis-configured **ACLs**.
 - Studying newer/advanced AD attack techniques: **ADCS abuse (ESC1 to ESC8), delegation attacks** (unconstrained, constrained, resource-based), **Shadow Credentials**, and **BloodHound**-driven attack path analysis.

PROJECTS

- Subdomain & Attack Surface Enumeration Tool** | Python, Requests, dnspython
Built a simple recon tool that finds subdomains from public sources like **crt.sh**, then takes a wordlist and strips out anything already found, then **brute-forces** the rest locally with **DNS** lookups. Scans open ports and fingerprints the tech stack on each host using **OpenVAS** along with several custom plugins for backend fingerprinting.
- Self-Maintained OpenVAS Scanner** | Nmap, NASL
Maintaining a custom fork of **OpenVAS** with custom **NASL** plugins I've written, mostly custom **CVE** checks that the default feed doesn't cover yet. Also wrote some extra fingerprinting logic for new software. Running AI-automated scripts to keep the feed updated with new **custom plugins** whenever new CVEs come out, so the scanner stays current instead of falling behind.
- Local Lab Setup**
 - Built a real world **Active Directory** setup at home with a **domain controller** and a couple of client machines, mainly to practice hands-on with AD attack paths like **Kerberoasting, LLMNR poisoning**, and **privilege escalation**.
 - pfSense + Vulnerable VMs:** Set up a home lab behind a **pfSense** firewall with a few intentionally vulnerable VMs (**Metasploitable, DVWA, VulnHub**) to practice scanning, exploiting, and generally get more comfortable with the full pentesting flow.

CERTIFICATIONS

- Offensive Security Certified Professional (OSCP) | OffSec | *In Progress*
- TCM Security: Practical Ethical Hacking • Windows & Linux Privilege Escalation • OSINT Fundamentals • External Pentest Playbook

EDUCATION

Malla Reddy College of Engineering & Technology, Hyderabad, India
Bachelor of Technology (B.Tech), Computer Science

2018 – 2022